

Vendor / SOC Reports (3rd-party financial systems)

Field	Value
Document ID	[SOX-ITGC-REP-004]
Version	1.0
Owner	[SOX IT Compliance Owner]
Effective Date	[Effective Date]
Framework	SOX IT General Controls
Classification	Confidential - Internal Use Only

Purpose

This report documents management's review of third-party SOC 1 reports for outsourced technology services that support financial reporting, including systems, applications, infrastructure, and managed services relied upon by the organisation's SOX IT general controls program.

The purpose of this report is to:

- Identify in-scope third-party service providers supporting financially relevant systems and processes.
- Confirm whether current SOC 1 reports have been obtained and reviewed.
- Evaluate the suitability of the SOC 1 report scope, audit period, opinion, control objectives, testing results, and user entity responsibilities.
- Identify exceptions, gaps, complementary user entity controls, subservice organisation dependencies, and carve-outs that may affect financial reporting reliance.
- Document management's conclusions regarding whether outsourced ITGCs may be relied upon for the reporting period.
- Define remediation actions, compensating controls, and follow-up activities where reliance is limited or unsupported.

This report is intended to support management's SOX assessment, external audit coordination, vendor risk oversight, and evidence retention for outsourced ITGCs.

Reporting Period & Scope

Reporting Period

This report covers the SOX reporting period from **[Start Date]** to **[End Date]**.

SOC 1 reports were assessed for relevance to the organisation's financial reporting reliance during the reporting period. Where a SOC 1 report period did not fully align with the SOX reporting period, bridge letters, management attestations, or complementary internal controls were evaluated.

In-Scope Vendor Services

The review includes third-party vendors that provide applications, platforms, infrastructure, hosting, managed operations, or other IT services that support financial systems or processes relevant to the organisation's financial statements.

In-scope services include, as applicable:

- Financial close, consolidation, and reporting platforms.
- Enterprise resource planning applications.
- Payroll processing platforms.
- Revenue, billing, invoicing, and receivables platforms.
- Procurement, payables, and expense management platforms.
- Cloud hosting or managed infrastructure supporting financially relevant applications.
- Managed database, access administration, batch processing, backup, or change deployment services.
- External service providers performing control activities on behalf of management.

In-Scope Vendors Reviewed

Vendor / Service Provider	Service / System Supported	Financial Reporting Relevance	SOC 1 Report Obtained	Report Period Covered	Report Type	Review Status
[Vendor 1]	[ERP Hosting / Managed Services]	High	Yes	[Date] to [Date]	Type 2	Complete
[Vendor 2]	[Payroll Processing Platform]	High	Yes	[Date] to [Date]	Type 2	Complete
[Vendor 3]	[Revenue Billing System]	High	Yes	[Date] to [Date]	Type 2	Complete
[Vendor 4]	[Financial Reporting Tool]	Medium	Yes	[Date] to [Date]	Type 2	Complete
[Vendor 5]	[Cloud Infrastructure Provider]	Medium	Yes	[Date] to [Date]	Type 2	Complete
[Vendor 6]	[Managed Database Services]	Medium	Pending	[Date] to [Date]	Type 2	In Progress

Out-of-Scope Areas

The following areas were not included in this report unless explicitly noted:

- SOC 2 reports, except where reviewed as supporting context for security, availability, or confidentiality controls that indirectly support SOX-relevant systems.
- Vendor financial condition, contract pricing, or commercial performance.
- Operational service-level performance unless it directly affects ITGC reliance.
- Business process controls performed by vendors unless included in a SOC 1 report and relevant to financial reporting.
- Vendors that do not support systems, interfaces, data, or operations relevant to financial reporting.

Executive Summary

Management reviewed SOC 1 reports for third-party service providers supporting financially relevant systems and outsourced ITGC activities. The review focused on whether the reports provide sufficient evidence to support reliance on vendor-operated controls for the SOX reporting period.

Overall, the reviewed SOC 1 reports provide a reasonable basis for reliance on outsourced ITGCs for the majority of in-scope vendors, subject to completion of identified user entity controls and remediation of open findings. No

report reviewed contained a qualified or adverse opinion. However, several matters require management attention, including timing gaps between SOC report coverage and the SOX year-end period, user entity control responsibilities requiring formal evidence, and subservice organisation carve-outs requiring additional assessment.

Overall Conclusion

Area	Conclusion
SOC 1 report availability	Current SOC 1 reports were obtained for most in-scope vendors. One report remains pending and requires follow-up.
Report suitability	Reports generally align to services used by the organisation and include ITGC areas relevant to financial reporting.
Auditor opinion	No adverse or qualified opinions were identified in the reports reviewed.
Control exceptions	Exceptions were noted in selected vendor reports; none currently indicate a material inability to rely, but management action is required.
User entity responsibilities	Several complementary user controls must be documented and evidenced internally.
Coverage gaps	Bridge letters or management representations are required where report periods do not cover the full SOX assessment period.
Reliance decision	Conditional reliance is supported for most vendors, pending completion of required actions.

Key Findings Summary

Finding ID	Vendor	Finding Theme	Severity	Status
F-01	[Vendor 1]	SOC report period does not fully cover SOX year-end	Medium	Open
F-02	[Vendor 2]	Complementary user entity controls not fully evidenced	Medium	Open
F-03	[Vendor 3]	Vendor access review exception noted in SOC report	Medium	Open
F-04	[Vendor 4]	Subservice organisation carved out of SOC report	Medium	Open
F-05	[Vendor 6]	SOC 1 report not yet received	High	Open
F-06	[Vendor 5]	No significant exceptions identified	Low	Closed

Management Assessment

Based on the review performed, management has determined that:

- Reliance on outsourced ITGCs is appropriate where SOC 1 reports were current, relevant, unqualified, and exceptions did not undermine control effectiveness.
- Reliance is conditional where bridge letters, user entity control evidence, or remediation follow-up remains outstanding.
- Reliance should not be finalised for vendors where SOC 1 reports have not been received or where report scope does not sufficiently cover the services used by the organisation.
- Action owners must complete remediation and evidence collection before SOX year-end control reliance is formally concluded.

Methodology

The SOC 1 review was performed using a standardised SOX ITGC vendor assessment approach. Each report was evaluated for relevance, completeness, timing, control coverage, test results, exceptions, management responses, subservice organisation dependencies, and user entity responsibilities.

Review Steps Performed

Step	Review Activity	Description
1	Vendor population validation	Confirmed vendors supporting financially relevant systems through application inventory, SOX scoping, procurement records, and vendor risk data.
2	SOC 1 report request	Requested current SOC 1 reports, bridge letters, and related management attestations from vendors or internal vendor owners.
3	Report authenticity check	Confirmed reports were issued by an independent service auditor and were complete, final, and not restricted to unrelated services.
4	Scope assessment	Compared report scope to the specific services, systems, locations, and control activities used by the organisation.
5	Period coverage assessment	Compared report coverage period to the organisation's SOX reporting period and identified any gap periods.
6	Opinion review	Reviewed service auditor opinion and management assertion for adverse, qualified, or disclaimed conclusions.
7	Control objective mapping	Mapped relevant vendor control objectives to ITGC domains relied upon by the organisation.
8	Exception analysis	Reviewed test exceptions, deviation descriptions, population impact, management responses, and remediation status.
9	User entity control evaluation	Identified complementary user entity controls and assessed whether internal control evidence exists.
10	Subservice organisation assessment	Identified carve-outs and inclusive subservice organisations and assessed additional reliance needs.
11	Reliance conclusion	Determined whether controls may be relied upon, conditionally relied upon, or not relied upon for SOX purposes.
12	Action tracking	Documented open actions, owners, due dates, and required evidence.

Assessment Criteria

The following criteria were applied when evaluating each SOC 1 report:

- The report is a SOC 1 Type 2 report for the relevant service period.
- The report covers the services, applications, infrastructure, or operations used by the organisation.
- The report period overlaps substantially with the organisation's SOX assessment period.
- Any gap between the report end date and the SOX reporting date is supported by a bridge letter or other appropriate evidence.
- The service auditor opinion does not indicate pervasive deficiencies.
- Control objectives and controls are relevant to financial reporting reliance.
- Exceptions are understood, assessed for impact, and remediated or compensated where necessary.
- Complementary user entity controls are identified, owned, and evidenced internally.

- Subservice organisations are reviewed where their controls are necessary to support reliance.
- Report restrictions are respected, and distribution is limited to authorised personnel.

ITGC Areas Considered

SOC 1 reports were evaluated for outsourced controls in the following ITGC areas where applicable:

ITGC Area	Relevant Vendor Control Activities Reviewed
Logical access	User provisioning, privileged access, access reviews, password configuration, authentication, termination processing
Change management	Change approval, testing, segregation of duties, migration to production, emergency changes
Computer operations	Job monitoring, incident management, backups, recovery, batch processing, interface monitoring
System development	Development lifecycle controls, testing, production migration, project governance
Data processing integrity	Transaction processing, file transfers, reconciliations, error handling, interface completeness
Security monitoring	Logging, alert review, vulnerability management, intrusion monitoring where relevant to financial systems
Physical and environmental controls	Data centre access, environmental safeguards, media protection where relevant to hosted services
Business continuity	Backup restoration, disaster recovery testing, recovery governance where required for financial reporting continuity

Detailed Findings / Results (with structure)

Vendor SOC 1 Review Results

Vendor	Report Obtained	Report Period Alignment	Opinion / Conclusion	Exceptions Noted	User Entity Controls Required	Subservice Considerations	Reliance Assessment
[Vendor 1]	Yes	Partial coverage; bridge required	Unmodified	Limited exceptions	Yes	None material	Conditional reliance
[Vendor 2]	Yes	Full coverage	Unmodified	No material exceptions	Yes	Carve-out noted	Conditional reliance
[Vendor 3]	Yes	Full coverage	Unmodified	Access review exception	Yes	None material	Conditional reliance
[Vendor 4]	Yes	Partial coverage; bridge required	Unmodified	No significant exceptions	Yes	Subservice carved out	Conditional reliance
[Vendor 5]	Yes	Full coverage	Unmodified	No significant exceptions	Limited	Inclusive method used	Reliance supported
[Vendor 6]	No	Not assessed	Not assessed	Not assessed	Unknown	Unknown	Reliance not yet supported

Finding F-01 - SOC Report Period Does Not Fully Cover SOX Year-End

Field	Detail
Vendor	[Vendor 1]
Service / System	[ERP Hosting / Managed Services]
Finding Type	Period coverage gap
Severity	Medium
Status	Open
Owner	[Vendor Owner / SOX IT Compliance Owner]

Field	Detail
Target Resolution Date	[Date]

Condition

The SOC 1 report for [Vendor 1] covers the period from [Date] to [Date], which does not fully cover the organisation's SOX reporting period through [Year-End Date]. A gap exists from [Date] to [Date].

Risk

Controls operated by the vendor during the gap period may not be independently tested. Without additional evidence, management may not have sufficient basis to rely on the vendor's ITGCs for the full SOX period.

Impact

The affected areas may include:

- Logical access administration for the hosted financial system.
- Production change management.
- Backup and job monitoring.
- Incident response and operational controls.

Evidence Reviewed

Evidence	Date Reviewed	Result
SOC 1 Type 2 report	[Date]	Report obtained and reviewed
Vendor bridge letter	[Date]	Not yet received
Vendor management representation	[Date]	Requested
Internal monitoring evidence	[Date]	Partially available

Management Conclusion

Reliance is conditional pending receipt and review of a bridge letter covering the gap period. If a bridge letter is not received, management must perform additional procedures, such as obtaining vendor attestations, reviewing complementary internal monitoring controls, or limiting reliance on vendor-operated controls.

Finding F-02 - Complementary User Entity Controls Not Fully Evidenced

Field	Detail
Vendor	[Vendor 2]
Service / System	[Payroll Processing Platform]
Finding Type	User entity control evidence gap
Severity	Medium
Status	Open
Owner	[Payroll Control Owner / SOX Control Owner]
Target Resolution Date	[Date]

Condition

The SOC 1 report identifies complementary user entity controls that must be performed by the organisation for the vendor's controls to operate effectively. Evidence was not complete for all required internal responsibilities.

Required User Entity Controls

User Entity Control Responsibility	Internal Owner	Evidence Status	Required Evidence
Timely notification of employee terminations	[HR Operations Owner]	Complete	Termination report and access removal evidence
Review of payroll system user access	[Payroll Manager]	Incomplete	Quarterly access review certification
Approval of payroll configuration changes	[Payroll Systems Owner]	Incomplete	Approved change tickets
Validation of payroll input and output files	[Payroll Operations Owner]	Complete	Reconciliation evidence
Review of exception reports	[Payroll Manager]	Partial	Exception report review sign-off

Risk

If user entity controls are not performed or evidenced, vendor controls may not fully address risks to payroll processing, access appropriateness, or financial reporting completeness and accuracy.

Impact

Management may be unable to rely on vendor controls unless the organisation can demonstrate that its own responsibilities were performed consistently during the period.

Management Conclusion

Reliance is conditional. Internal control owners must provide complete evidence for all required user entity controls before final SOX reliance is concluded.

Finding F-03 - Vendor Access Review Exception Noted in SOC Report

Field	Detail
Vendor	[Vendor 3]
Service / System	[Revenue Billing System]
Finding Type	Vendor control exception
Severity	Medium
Status	Open
Owner	[Application Owner / Vendor Manager]
Target Resolution Date	[Date]

Condition

The SOC 1 report identified an exception related to periodic access reviews. The service auditor noted that for a sample of privileged users, evidence of timely review or approval was not available.

Risk

Inadequate review of privileged access may increase the risk of unauthorised changes to billing configuration, revenue data, user permissions, or system processing rules.

Impact Assessment

Factor	Assessment
Control area affected	Logical access
User type affected	Privileged vendor users
Financial reporting relevance	High
Population impact	Limited based on report details
Compensating controls	Internal review of organisation-managed users; vendor access restriction process
Residual risk	Moderate until remediation evidence is obtained

Evidence Reviewed

- SOC 1 exception description.
- Vendor management response.
- Vendor remediation statement.
- Internal access review evidence for organisation-managed accounts.
- Access listing provided by [Vendor 3], where available.

Management Conclusion

The exception does not automatically preclude reliance, but additional follow-up is required. Management must obtain vendor remediation evidence or a written confirmation that the access review process was corrected and operated effectively after remediation.

Finding F-04 - Subservice Organisation Carved Out of SOC Report

Field	Detail
Vendor	[Vendor 4]
Service / System	[Financial Reporting Tool]
Finding Type	Subservice organisation carve-out
Severity	Medium
Status	Open
Owner	[Vendor Risk Manager / System Owner]
Target Resolution Date	[Date]

Condition

The SOC 1 report for [Vendor 4] excludes certain control activities performed by a subservice organisation that supports hosting, infrastructure, security monitoring, or data processing services.

Risk

Controls performed by the subservice organisation may be necessary to support reliance on the outsourced service. If those controls are not reviewed, management may have an incomplete view of the end-to-end ITGC environment.

Impact

Potential affected control areas include:

- Data centre and hosting controls.
- Network and infrastructure security.
- Backup and recovery operations.
- Logical access to infrastructure components.
- Change management for hosted environments.

Required Follow-Up

Required Action	Owner	Due Date	Status
Identify carved-out subservice organisation and services provided	[Vendor Owner]	[Date]	Open
Determine whether subservice controls are relevant to SOX reliance	[SOX IT Compliance Owner]	[Date]	Open
Obtain subservice SOC 1 or other suitable assurance report if required	[Vendor Risk Manager]	[Date]	Open
Document compensating controls if report is unavailable	[System Owner]	[Date]	Open

Management Conclusion

Reliance is conditional until management determines whether the carved-out subservice organisation performs controls required to support financial reporting reliance.

Finding F-05 - SOC 1 Report Not Yet Received

Field	Detail
Vendor	[Vendor 6]
Service / System	[Managed Database Services]
Finding Type	Missing assurance report
Severity	High
Status	Open
Owner	[Vendor Manager]
Target Resolution Date	[Date]

Condition

A current SOC 1 report has not yet been received for [Vendor 6]. The vendor supports services used by [Financial System], which is relevant to financial reporting.

Risk

Without a current SOC 1 report or equivalent evidence, management may be unable to assess whether outsourced ITGCs operated effectively during the SOX reporting period.

Impact

The absence of a report may affect reliance on:

- Database access controls.

- Privileged administration.
- Change deployment support.
- Backup monitoring.
- Incident management.
- Service availability for financial close activities.

Interim Procedures

Until the SOC 1 report is obtained, management should perform the following interim procedures:

Procedure	Owner	Evidence Required	Status
Obtain vendor management assertion over relevant controls	[Vendor Manager]	Signed attestation	Open
Request listing of privileged vendor administrators	[System Owner]	Access listing and review evidence	Open
Review internal monitoring of vendor change tickets	[Application Owner]	Approved change records	Open
Confirm backup and recovery monitoring responsibilities	[Infrastructure Owner]	Backup monitoring evidence	Open
Assess incident history during reporting period	[IT Operations Owner]	Incident report and review sign-off	Open

Management Conclusion

Reliance is not currently supported. Final reliance requires receipt and review of the SOC 1 report or completion of sufficient alternative procedures approved by SOX management and, where applicable, aligned with external audit expectations.

Finding F-06 - No Significant Exceptions Identified

Field	Detail
Vendor	[Vendor 5]
Service / System	[Cloud Infrastructure Provider]
Finding Type	No significant exception
Severity	Low
Status	Closed
Owner	[Cloud Platform Owner]
Target Resolution Date	Not applicable

Condition

The SOC 1 report was obtained, reviewed, and found to be relevant to the services used by the organisation. The report period aligns with the SOX reporting period, and no exceptions were identified that affect reliance on relevant outsourced ITGCs.

Evidence Reviewed

Evidence	Result
SOC 1 Type 2 report	Complete and current
Report scope	Relevant to services used

Evidence	Result
Auditor opinion	Unmodified
Exceptions	No significant exceptions affecting reliance
Subservice organisations	Included or not relevant to SOX reliance
User entity controls	Limited and addressed internally

Management Conclusion

Reliance is supported for relevant vendor-operated controls, subject to continued performance of internal monitoring and user entity responsibilities.

Analysis

Overall SOC 1 Coverage

The review indicates that the organisation has established a functioning process to obtain and evaluate SOC 1 reports for third-party providers supporting financial reporting. Most high-risk vendors have current SOC 1 reports available, and the reports generally cover logical access, change management, operations, and security controls relevant to SOX ITGC reliance.

However, the process requires continued attention in the following areas:

- Timely collection of reports before SOX testing and year-end reliance deadlines.
- Formal tracking of report period gaps and bridge letter requirements.
- Consistent mapping of complementary user entity controls to internal SOX control evidence.
- Review of subservice organisation carve-outs where vendor services depend on third-party infrastructure or processing.
- Documentation of management's reliance conclusion for each vendor.

Report Period Alignment

SOC 1 reporting periods rarely align perfectly with the organisation's SOX reporting period. Where reports end before SOX year-end, management must obtain bridge letters or perform additional procedures covering the gap. Period gaps are not necessarily control failures, but unresolved gaps may reduce the evidence available to support reliance.

Coverage Scenario	Management Response
SOC 1 period fully covers SOX period	Reliance may be supported if scope and results are acceptable
SOC 1 period covers most but not all of SOX period	Obtain bridge letter or perform gap-period procedures
SOC 1 period is outdated	Request current report and consider alternative procedures
SOC 1 report unavailable	Reliance not supported until sufficient evidence is obtained
Report scope does not match services used	Determine whether other evidence is required or reliance should be limited

Complementary User Entity Controls

SOC 1 reports commonly assume that the user organisation performs certain controls. These controls are not optional; they are necessary for the vendor's controls to be effective in the organisation's environment.

Common responsibilities identified across reports include:

- Approving and periodically reviewing user access.
- Notifying vendors promptly of user terminations and role changes.
- Restricting privileged access requests to authorised personnel.
- Reviewing system-generated reports and processing exceptions.
- Reconciling input and output files.
- Approving configuration and master data changes.
- Monitoring vendor service issues and incidents.
- Maintaining internal policies and procedures for system use.

Where these responsibilities are not evidenced, the organisation's ability to rely on the vendor's controls may be impaired even if the vendor's SOC 1 report is otherwise clean.

Exception Severity Assessment

SOC 1 exceptions were assessed based on nature, frequency, population impact, financial reporting relevance, and whether compensating controls exist.

Severity	Description	Typical Management Response
High	Exception affects a key outsourced control and may materially impact reliance	Do not rely until remediated or alternative procedures are completed
Medium	Exception affects a relevant control but appears limited or compensating controls may exist	Conditional reliance with follow-up and documented mitigation
Low	Exception does not affect controls relied upon or has minimal impact	Reliance may continue with monitoring
Informational	Observation does not indicate control failure but may improve oversight	Track as improvement item

Subservice Organisation Considerations

Subservice organisations may perform controls that are important to the vendor's service delivery. If such organisations are carved out of the vendor's SOC 1 report, management must determine whether their controls are relevant to SOX reliance.

Examples include:

- Cloud infrastructure providers hosting financial systems.
- Data centre operators supporting vendor applications.
- Payment processors supporting transaction flows.
- Managed security providers monitoring vendor environments.
- Third-party database or platform administrators.

Where relevant subservice controls are not included in the vendor's report, management should obtain additional assurance reports, vendor confirmations, or evidence of compensating controls.

Reliance Determination Summary

Reliance Category	Vendors	Criteria
Reliance supported	[Vendor 5]	Report obtained, relevant scope, acceptable period, no significant exceptions, user entity controls addressed
Conditional reliance	[Vendor 1], [Vendor 2], [Vendor 3], [Vendor 4]	Report obtained but follow-up required for gap period, user controls, exceptions, or subservice carve-outs
Reliance not yet supported	[Vendor 6]	SOC 1 report not received or sufficient alternative evidence not yet available

Recommendations & Actions

Priority Recommendations

Management should complete the following actions before finalising SOX reliance on outsourced ITGCs:

- Obtain all outstanding SOC 1 reports and bridge letters.
- Complete documented reviews for each in-scope report using a standard review template.
- Map all complementary user entity controls to internal SOX controls and evidence.
- Obtain remediation evidence for SOC 1 exceptions that affect relevant ITGCs.
- Review subservice organisation carve-outs and obtain additional assurance where needed.
- Document formal reliance conclusions for each vendor.
- Escalate unresolved high-risk gaps to SOX leadership and external audit stakeholders.
- Maintain a central repository for SOC reports, bridge letters, reviews, conclusions, and related evidence.

Action Plan

Action ID	Action	Priority	Owner	Due Date	Required Evidence	Status
A-01	Obtain bridge letter for [Vendor 1] covering [Date] to [Date]	High	[Vendor Owner]	[Date]	Signed bridge letter	Open
A-02	Complete evidence collection for payroll user entity controls	High	[Payroll Control Owner]	[Date]	Access review, change approvals, reconciliations	Open
A-03	Obtain remediation evidence for [Vendor 3] access review exception	Medium	[Application Owner]	[Date]	Vendor remediation confirmation	Open
A-04	Assess [Vendor 4] subservice carve-out and obtain additional report if required	Medium	[Vendor Risk Manager]	[Date]	Subservice assessment and report	Open
A-05	Obtain current SOC 1 report for [Vendor 6]	High	[Vendor Manager]	[Date]	SOC 1 report and completed review	Open
A-06	Perform alternative procedures for [Vendor 6] if report is delayed	High	[SOX IT Compliance Owner]	[Date]	Alternative testing evidence	Open
A-07	Finalise reliance conclusions for all vendors	High	[SOX IT Compliance Owner]	[Date]	Signed reliance summary	Open

Action ID	Action	Priority	Owner	Due Date	Required Evidence	Status
A-08	Update vendor SOC 1 tracking register	Medium	[GRC Analyst]	[Date]	Updated tracker	Open

Required Evidence Package

For each in-scope vendor, the evidence package should include:

Evidence Item	Required	Notes
Current SOC 1 Type 2 report	Yes	Must cover relevant services used by the organisation
Bridge letter	If applicable	Required where report period does not cover SOX year-end
SOC report review checklist	Yes	Must document scope, period, opinion, exceptions, and conclusion
Complementary user entity control mapping	Yes	Must identify internal owners and related evidence
Exception impact assessment	If applicable	Required for any relevant SOC 1 exception
Subservice organisation assessment	If applicable	Required where subservice controls are carved out or critical
Vendor remediation evidence	If applicable	Required where exceptions affect reliance
Management reliance conclusion	Yes	Must be approved by SOX IT Compliance Owner
External audit correspondence	If applicable	Retain where reliance approach was discussed

Escalation Criteria

Issues should be escalated to [SOX Program Lead], [Controller], [CIO], or [Audit Committee Liaison] when any of the following occur:

- A high-risk vendor does not provide a current SOC 1 report.
- A SOC 1 report contains a qualified, adverse, or otherwise concerning opinion.
- Exceptions affect key outsourced controls without effective remediation.
- Required user entity controls were not performed or cannot be evidenced.
- A significant subservice organisation is carved out and no additional assurance is available.
- Vendor management refuses to provide sufficient assurance evidence.
- External audit raises concerns regarding reliance on outsourced controls.
- Remediation will not be completed before SOX year-end reporting deadlines.

Target Completion Timeline

Milestone	Target Date	Owner
Confirm in-scope vendor population	[Date]	[SOX IT Compliance Owner]
Obtain SOC 1 reports and bridge letters	[Date]	[Vendor Owners]
Complete SOC 1 reviews	[Date]	[GRC Analyst / SOX IT Team]
Complete user entity control evidence collection	[Date]	[Control Owners]
Complete exception and carve-out assessments	[Date]	[SOX IT Compliance Owner]
Finalise management reliance conclusions	[Date]	[SOX Program Lead]
Provide evidence package to external audit	[Date]	[SOX IT Compliance Owner]

Distribution & Confidentiality

This report contains confidential information regarding third-party control environments, vendor assurance reports, financial systems, SOX control reliance, and internal control assessments. Distribution must be limited to personnel with a legitimate business need.

Approved Distribution

Recipient Group	Purpose
[SOX Program Lead]	Oversight of SOX control reliance and remediation
[SOX IT Compliance Team]	Review, evidence management, and action tracking
[System Owners]	Resolution of system-specific findings
[Vendor Owners]	Vendor follow-up and assurance collection
[Finance Control Owners]	Completion of user entity controls
[Internal Audit]	Independent review and SOX coordination
[External Audit]	Audit reliance and evidence review
[Executive Management, as required]	Escalation of significant unresolved risks

Confidentiality Requirements

- SOC 1 reports and related vendor assurance materials must be handled in accordance with vendor confidentiality restrictions.
- Reports must not be forwarded outside approved distribution without authorisation from [Legal / Vendor Management / SOX Program Lead].
- SOC 1 reports must be stored only in approved repositories with restricted access.
- Extracts from SOC 1 reports should be limited to information necessary for SOX review and audit evidence.
- Vendor reports must not be uploaded to unauthorised collaboration tools, public repositories, or unmanaged storage locations.
- Any suspected unauthorised disclosure must be reported immediately to [Information Security Contact] and [Legal Contact].

Retention

This report and supporting evidence must be retained in accordance with the organisation's SOX evidence retention requirements and legal hold obligations. At a minimum, the retained evidence should include:

- Final version of this report.
- SOC 1 reports reviewed.
- Bridge letters and vendor attestations.
- Completed SOC report review checklists.
- User entity control evidence.
- Exception assessments and remediation evidence.
- Subservice organisation assessments.
- Final reliance conclusions and approvals.

Approval

Role	Name	Approval Date	Signature / Evidence
SOX IT Compliance Owner	[Name]	[Date]	[Electronic Approval Reference]
SOX Program Lead	[Name]	[Date]	[Electronic Approval Reference]
Finance Control Owner	[Name]	[Date]	[Electronic Approval Reference]
Internal Audit Reviewer	[Name]	[Date]	[Electronic Approval Reference]